

[AP 03] Demuestra tus habilidades



Informe de Evaluación de Riesgos

Analista: Xavier Margalef Riestra

Fecha: 2026-06-01

Clasificación: Interna / Formación

1. Ataque Ransomware en un Hospital

- **Amenaza principal:** Ransomware.
-

- **Vulnerabilidad:** entendemos vulnerabilidad como algo explotable como una tienda con escaparate, aquí la falta de copias de seguridad recientes y la posible falta de segmentación de red o del correcto uso de virtualización para segmentar servicios, que permite movilidad del malware.
-

- **Salvaguarda:**
 - **Técnica:** copias de seguridad periódicas con el uso de crontab rescatando el término del anterior ejercicio e implementación de sistemas EDR y AV actualizados al mercado.
 - **Administrativa:** políticas de backup.
 - **Física:** mejora de control de acceso para evitar entrada directa de hardware con ransomware malicioso, ya que es una posibilidad considerando que no se indica cómo se infecta.
-

- **PDCA:** aquí se vería impactado el **Plan**, que entraría a definir y revisar la estrategia de continuidad, políticas y planes de mejora, y el **Act**, ya que es la fase de postmortem en cuanto a recuperar los datos, limpiar el sistema e implementar salvaguardas que permite activar el ciclo y planear, un denominador común después de cualquier incidente.
-

- **Clasificación: Ciberseguridad** ya que el ransomware ha vencido las implementaciones, estrategias y herramientas de seguridad existentes desde su entrada hasta su disclosure y denial, con impacto en **Seguridad de la Información** que es lo que se ha visto expuesto, lo que es el activo de la información que en este caso son los historiales críticos y por tanto la confidencialidad de los usuarios y la disponibilidad al acceso a estos.
-

- **Evaluación de riesgo: Crítico**

Establecido bajo el framework matemático de $\text{Riesgo} = \text{Impacto} \times \text{Probabilidad}$:

- **Impacto Muy Alto:** debido a la interrupción de atención médica a la hora de revisar información vital, sumada a la propia pérdida de datos de salud muy personales (nivel derechos fundamentales) que impacta en la confidencialidad, más daño reputacional al hospital.
- **Probabilidad Alta:** ya que los hospitales son objetivos frecuentes por su vulnerabilidad por sistemas informáticos débiles no al día y con datos cruciales para la vida que requieren de una recuperación urgente lo cual es más atractivo para un ciber-criminal.

2. Filtración de Datos en una Empresa de Tecnología

- **Amenaza principal:** envío accidental de datos sensibles por error humano, negligencia profesional. Me sonaba que esto tenía un nombre y lo he buscado: [insider threat](#).
-
- **Vulnerabilidad:** falta de política de gestión de datos por permisos y falta de control y revisión por software de salida por canales profesionales.
-
- **Salvaguarda:**
 - **Administrativa:** implementar política de control de acceso y permisos IAM que limite el acceso a la información según posición o rol aplicando modelos como Bell-LaPadula + mejorar la formación y concienciación continua en los empleados acerca de la seguridad de la información.
 - **Técnica:** implementar sistemas de monitorización, bloqueo y notificación de envío de datos sensibles o archivos con contenido relevante.
 - **Física:** no aplicaría.
-
- **PDCA: Plan** (definir procedimientos y políticas habladas en la sección de salvaguardas), **Check** (auditar, controlar y monitorizar continuamente mediante el uso de la herramienta de control de salida de datos), y **Act** como hemos visto antes entendiendo que esto permite activar el sistema de hardening con la planificación.
-
- **Clasificación: Seguridad de la Información** debido a que no hay un ataque que ponga en juego las implementaciones y metodologías de ciberseguridad, sino que hay una falla en la estrategia y política que protege el activo información por lo cual hay que planear cómo proteger mejor esta seguridad de la información. Las herramientas existentes y sus profesionales de ciberseguridad y seguridad informática han cumplido sus papeles, el problema es que había una vulnerabilidad no prevista.
-
- **Evaluación de riesgo: Crítico**

Establecido bajo el framework matemático de $\text{Riesgo} = \text{Impacto} \times \text{Probabilidad}$:

 - **Impacto Alto:** debido a pérdida de confidencialidad de clientes que rompe uno de los principios de la seguridad de la información, sanciones por violaciones de confidencialidad, y daño reputacional.
 - **Probabilidad Alta:** realísticamente aunque haya políticas, herramientas y concienciación, tal y como indican las estadísticas, los errores humanos suponen la mayoría de causas de fallas a la seguridad de la información por lo que es probable que esto pase. De hecho, recientemente un usuario de Paramount envió una película entera de animación a un tercero sin querer y esta ha sido colgada en redes.

3. Falla en un Sistema Crítico de una Planta Industrial

- **Amenaza principal:** fallo operacional en el ICS debido a software vulnerable no parcheado que expone a la manipulación de los PLC.
-
- **Vulnerabilidad:** bug conocido sin parchear en el software de control, falta de parcheo y revisión de CVE públicos.
-
- **Salvaguarda:**
 - **Técnica:** aplicar implementaciones administrativas y políticas de parcheo de vulnerabilidades conocidas, implementar pruebas testing y QA.
 - **Administrativa:** establecimiento de estrategias y políticas de ciberseguridad rigurosas que revisen vulnerabilidades y establezcan un calendario de mantenimiento preventivo.
 - **Física:** protección de accesos a equipos y controles industriales por vías físicas que puedan manipular los PLCs.
-
- **PDCA: Plan** (diseño previo del calendario de mantenimiento preventivo y de la estrategia de gestión de vulnerabilidades), **Check** (verificar el estado del software y detectar fallos, monitorizar errores y accesos, y auditar) y **Act** (corregir el bug, mejorar la gestión de mantenimiento y activar la retroalimentación del ciclo).
-
- **Clasificación: Ciberseguridad Industrial.**
-
- **Evaluación de riesgo: Crítico**

Establecido bajo el framework matemático de $\text{Riesgo} = \text{Impacto} \times \text{Probabilidad}$:

 - **Impacto Alto:** pérdidas económicas significativas y detención completa de la producción industrial.
 - **Probabilidad Alta:** el entorno industrial seguro que tiene sistemas y hardware desfasados a nivel IoT con vulnerabilidades no parcheadas de sistemas antiguos.

4. Acceso No Autorizado a un Servidor Bancario

- **Amenaza principal:** atacante externo usando credenciales extraídas de la dark web.
-

- **Vulnerabilidad:** servidor mal configurado sin autenticación fuerte ni doble autenticación, reutilización de credenciales filtradas, y falta de sistema de monitoreo como SIEM que detecte inicios de sesión anómalos.
-

- **Salvaguarda:**

- **Técnica:** autenticación multifactor (MFA o 2FA), hardening de servidores, mejorar IAM, mejora o implementación de SIEM.
 - **Administrativa:** establecimiento de políticas y metodologías de contraseñas (por ejemplo cambiar cada mes, formato mínimo, etc), y formación y concienciación.
 - **Física:** no aplica directamente ya que el robo ha sido por red y no por robo presencial/visual por acceso no autorizado al centro empresarial.
-

- **PDCA: Plan** (diseñar las estrategias y políticas de acceso, contraseñas, formación para evitar desde el nivel Seguridad de la Información), **Do** (para solucionar el problema causado por la filtración y acceso no autorizado con todo lo que comporta: password resets, activar el MFA o 2FA, hardening del sistema y servidor), **Check** (monitorear y auditar accesos, revisar configuraciones periódicamente) y **Act** (ya que toda esta planificación y correcciones vienen dadas por una revisión postmortem).
-

- **Clasificación: Ciberseguridad** ya que se ha perpetrado un ataque que ha superado las herramientas y metodologías implementadas por los equipos de ciberseguridad, y **Seguridad de la Información** ya que han faltado políticas y estrategias de las mismas.
-

- **Evaluación de riesgo: Crítico**

Establecido bajo el framework matemático de $\text{Riesgo} = \text{Impacto} \times \text{Probabilidad}$:

- **Impacto Muy Alto:** exposición de datos bancarios, operaciones no autorizadas y fraudulentas, multas regulatorias severas, fraude directo y daño reputacional corporativo.
- **Probabilidad Alta:** el uso de credenciales filtradas es un riesgo común en servicios bancarios, según reportes de incidencias hay bots atacando continuamente explorando vulnerabilidades, etc.

5. Robo de Equipos con Información Sensible

- **Amenaza principal:** robo físico de dispositivos y de sus datos no cifrados.
-

- **Vulnerabilidad:** ausencia de cifrado en los portátiles y falta de control de acceso físico y monitoreo de actividad en las instalaciones así como de herramienta de gestión de dispositivos que permita borrado de datos en caso de robo o pérdida.
-

- **Salvaguarda:**
 - **Física:** aquí sí es la más importante y la más crítica que permite que el resto de vulnerabilidades sean explotadas, hay que implementar control de acceso a instalaciones, cámaras, cerraduras y vigilancia.
 - **Técnica:** cifrado de disco y gestión de dispositivos ([MDM](#)).
 - **Administrativa:** políticas de seguridad física y respuesta ante robo.
-

- **PDCA: Plan** (definir seguridad física, de perímetros, de acceso y seguridad de protección de equipos, acceso biométrico, software a implementar como MDM), **Act** (como ya ha pasado toca analizar, evaluar postmortem y corregir retroalimentando con Plan para entender cómo hay que corregir y buscar la mejora continua).
-

- **Clasificación: Seguridad de la Información con Seguridad Física.**

Aquí la explotación de la vulnerabilidad viene dada por una deficiente política que proteja el activo tanto en su lado físico como digital. No se han vencido medidas de ciberseguridad sino que no existían por falta de estrategia metodológica a nivel de arquitectura.

- **Evaluación de riesgo: Alto**

Establecido bajo el framework matemático de $\text{Riesgo} = \text{Impacto} \times \text{Probabilidad}$:

- **Impacto Alto:** acceso a activo información que vulnera la confidencialidad, expone a posible alteración (dentro de la triada DAD como contrario a la confidencialidad, integridad y disponibilidad) y uso con fines comerciales y fraudulentos.
- **Probabilidad Media:** hoy en día no tener protección física ni digital es menos probable, y la entrada física a una empresa expone al atacante en su integridad física.

6. Fraude por Ingeniería Social

- **Amenaza principal:** fraude mediante ingeniería social y phishing.
-

- **Vulnerabilidad:** falta de política de verificación de acciones financieras y educación digital/concienciación; al empleado no ha tenido claro que ante la duda reporte o consulte.
-

- **Salvaguarda:**

- **Administrativa:** políticas de verificación de pagos, formación en detección de phishing y procedimientos de doble verificación.
 - **Técnica:** filtros antiphishing y alertas de correo electrónico.
 - **Física:** no aplicaría.
-

- **PDCA: Plan** (establecer las políticas de control y herramientas y software de verificación para transacciones económicas dentro de la red y/o dispositivos de trabajo, así como mejorar los planes de concienciación), **Do** (implementar y ejecutar los filtros técnicos antiphishing configurados y realizar las sesiones de formación/concienciación a los empleados), **Check** (auditar y supervisar las transacciones y cumplimiento de las políticas) y **Act** (entender qué ha pasado, el porqué, y planificar las mejoras).
-

- **Clasificación: Seguridad de la Información**, no se compromete la infraestructura, sino que ha habido una vulnerabilidad explotada que lo ha sido por falta de previsión técnica y formativa.
-

- **Evaluación de riesgo: Crítico**

Establecido bajo el framework matemático de $\text{Riesgo} = \text{Impacto} \times \text{Probabilidad}$:

- **Impacto Alto:** el desvío de 100.000 € podría equivaler a un SEV1 en incidentes provocados por fallo o bug en software, sumado al riesgo de consecuencias legales y reputacionales.
- **Probabilidad Alta:** como hemos comentado antes el error humano es más del 90% de la causa de vulneraciones de la seguridad de la información, y el phishing como hemos visto en clase es el método más sencillo y barato y puede tirar de OSINT e ingeniería social al cual mucha gente tiene acceso y facilidades.